



Economics of Information Security

www.infoecon.net

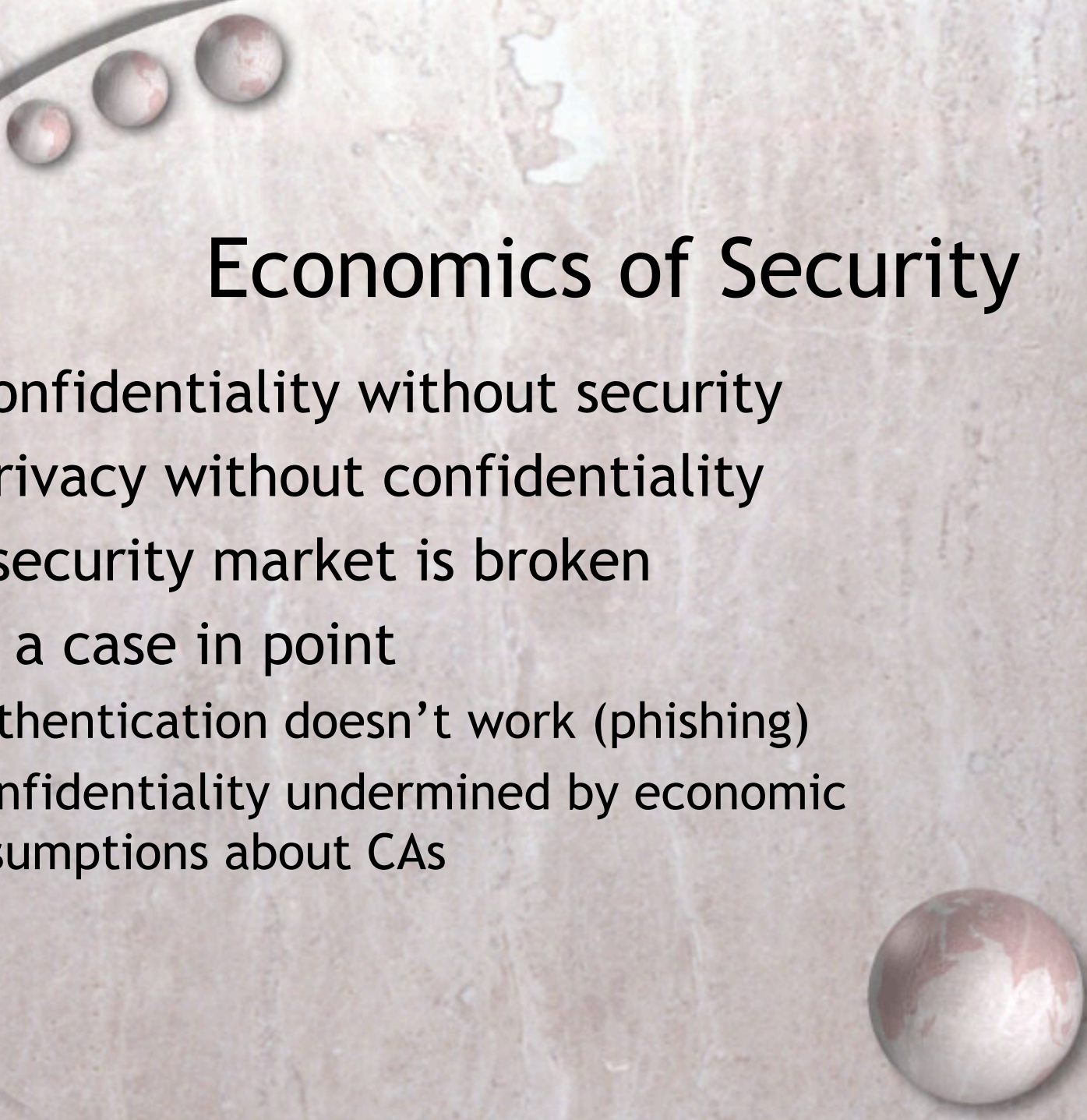
www.ljean.com

Emergence of a (sub) Discipline



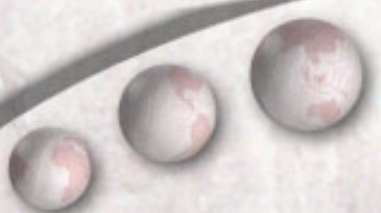


Economics of whoops!



Economics of Security

- No confidentiality without security
- No privacy without confidentiality
- The security market is broken
- SSL - a case in point
 - Authentication doesn't work (phishing)
 - Confidentiality undermined by economic assumptions about CAs



Economics of Information Security

- Fundamentals - what kind of good?
 - Valuing investments - ROI, using classic business methods
 - Privacy
 - Openness - Sharing vs Secrecy
 - Case Studies
- 

Security as an Externality

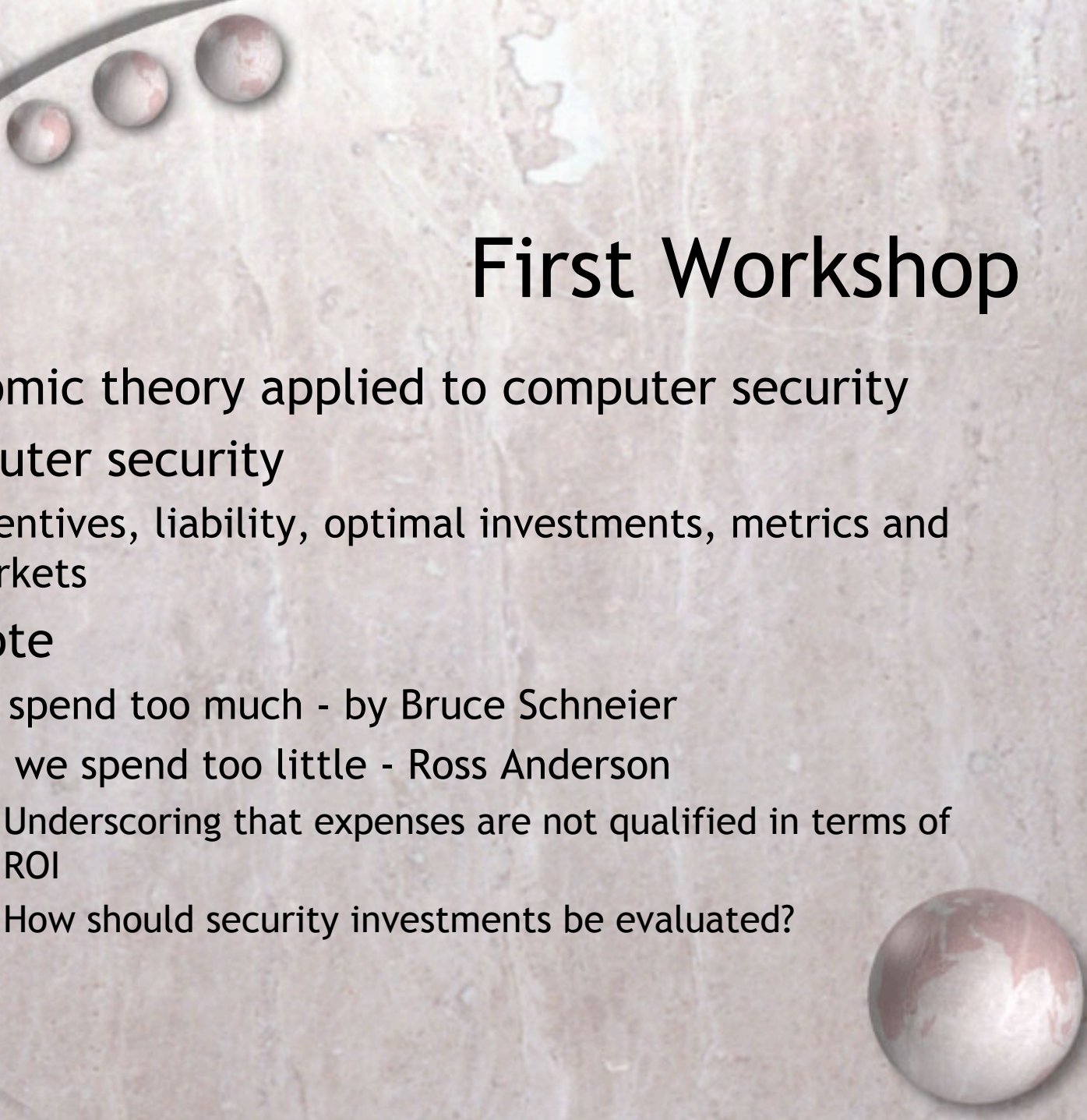
- Vulnerabilities are a negative externality
 - Polluters will go on producing pollution until the costs *to the polluter* outweigh the benefits.
 - Those who abuse personal data will go on until the costs *to the abuser* outweigh the benefits.
- Secure systems offer positive externalities
 - Lojack causes auto theft in a neighborhood to go down because it is not visible
 - High levels of trust increase Internet use and value

Security As an Externality

- Shared trust
 - rhosts
 - Password files
 - Address books
- Increased resources
 - DDoS attacks
- The ability for the attacker to confuse the trail

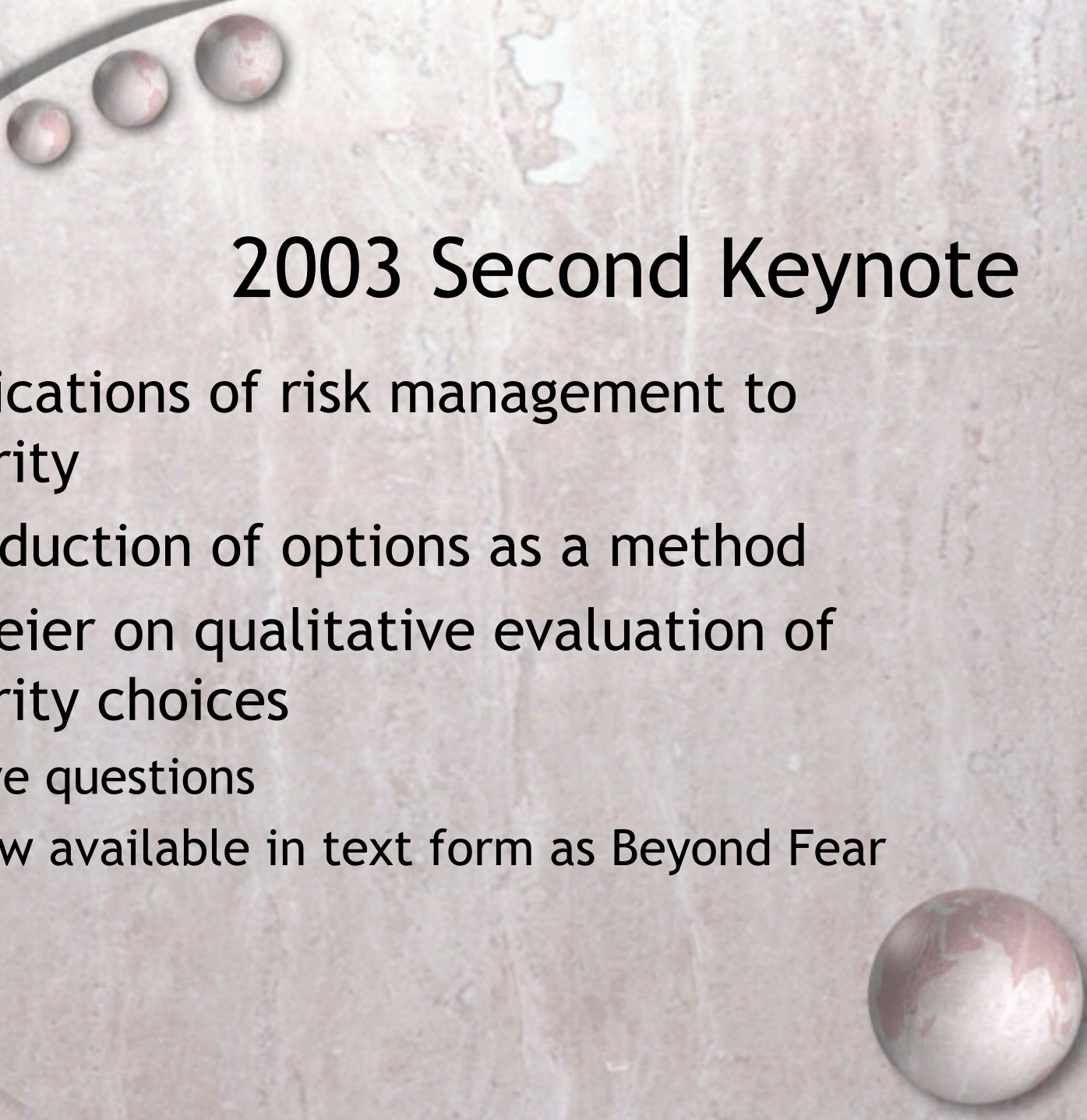
Governmental Responses to Externalities

- Information provision
 - Classification
 - Standards settings
- Rule-making
 - Prohibitions
- Subsidies
 - Support incident response teams (e.g. provision of the good),
 - Purchase secure technologies
 - Support computer security research



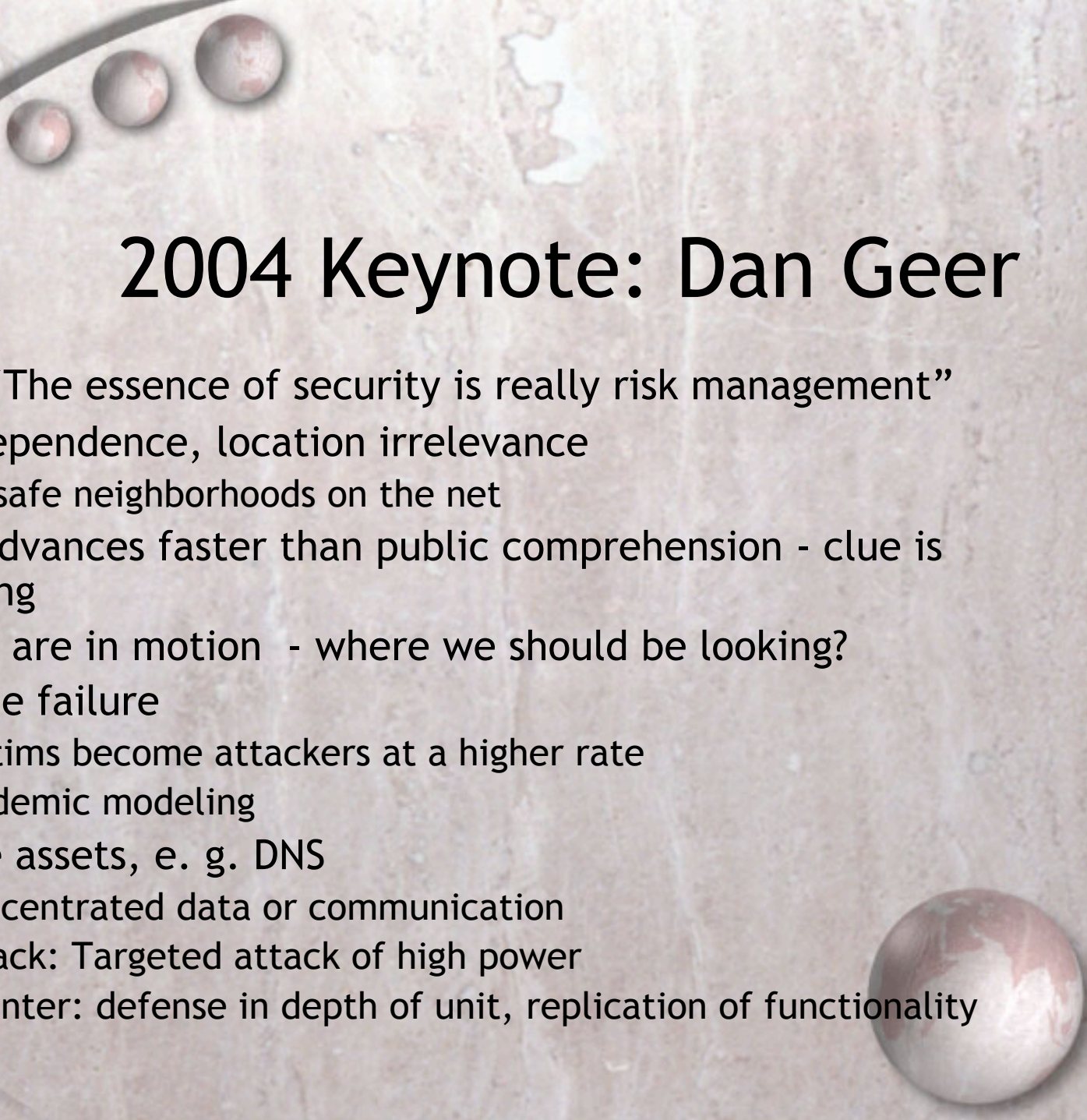
First Workshop

- Economic theory applied to computer security
- Computer security
 - Incentives, liability, optimal investments, metrics and markets
- Keynote
 - We spend too much - by Bruce Schneier
 - No, we spend too little - Ross Anderson
 - Underscoring that expenses are not qualified in terms of ROI
 - How should security investments be evaluated?



2003 Second Keynote

- Applications of risk management to security
- Introduction of options as a method
- Schneier on qualitative evaluation of security choices
 - Five questions
 - Now available in text form as Beyond Fear

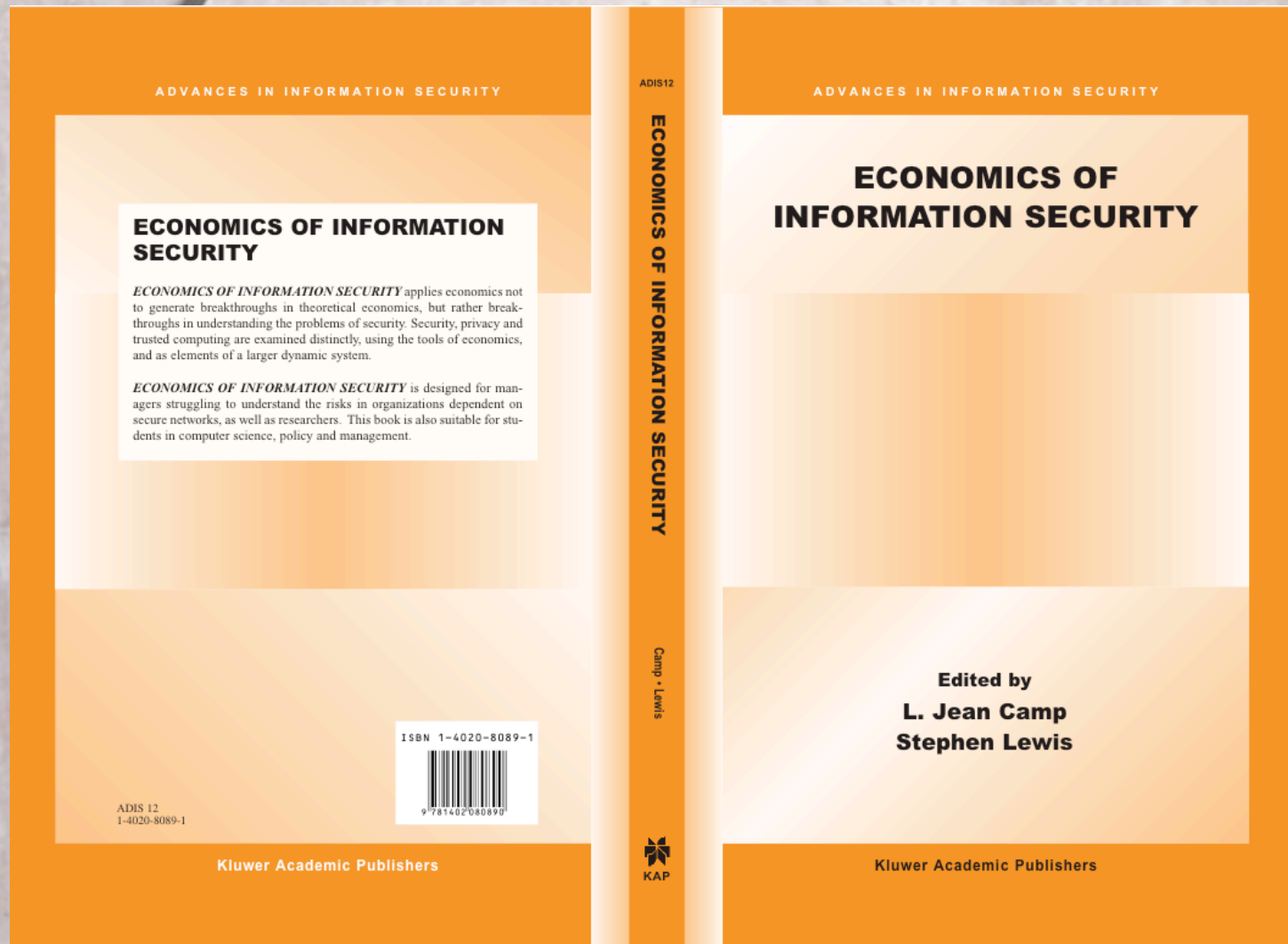


2004 Keynote: Dan Geer

“The essence of security is really risk management”

- Interdependence, location irrelevance
 - No safe neighborhoods on the net
- Tech advances faster than public comprehension - clue is dropping
- Assets are in motion - where we should be looking?
- Cascade failure
 - Victims become attackers at a higher rate
 - Epidemic modeling
- Unique assets, e. g. DNS
 - Concentrated data or communication
 - Attack: Targeted attack of high power
 - Counter: defense in depth of unit, replication of functionality

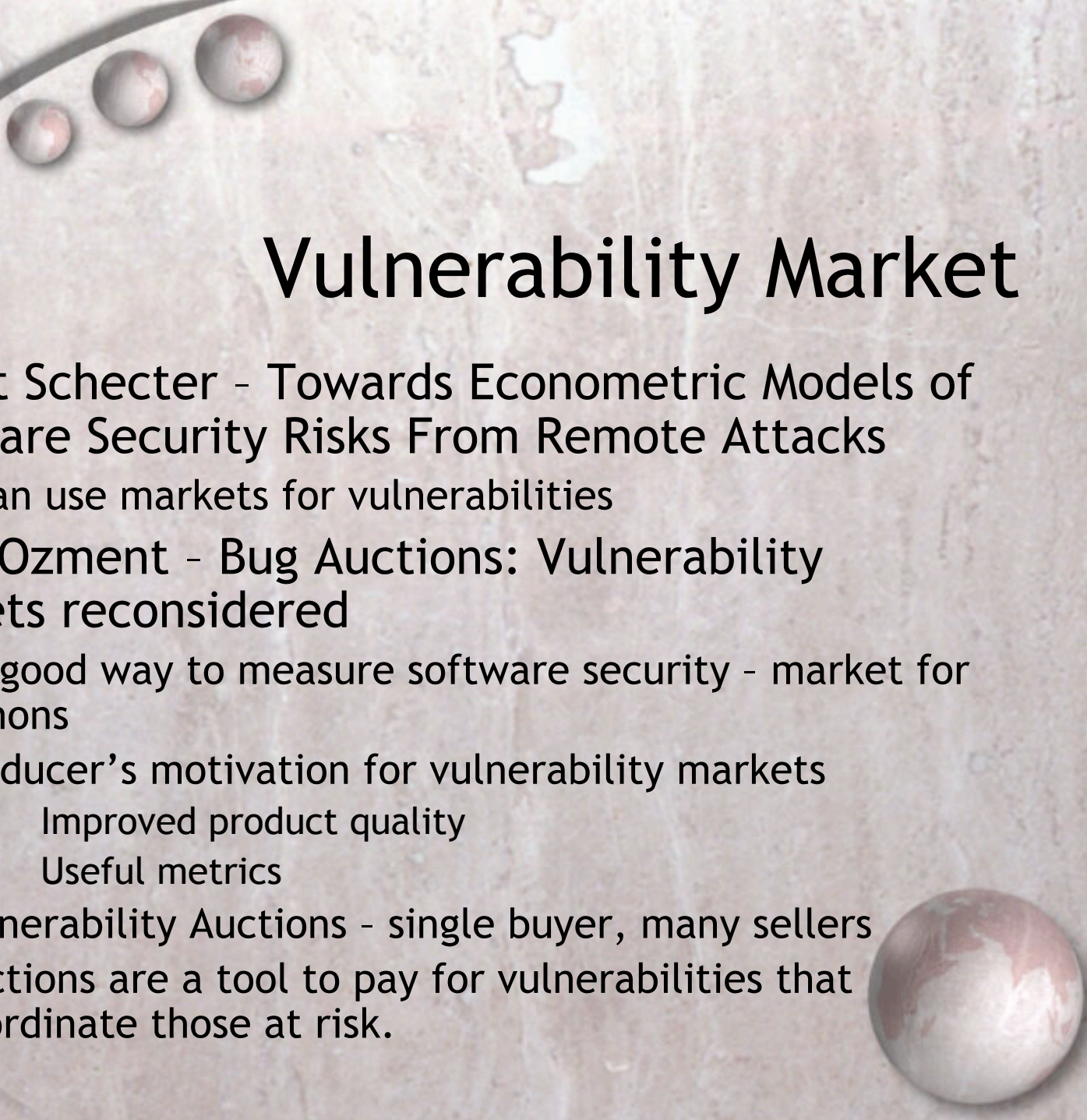
Third Workshop & New Text





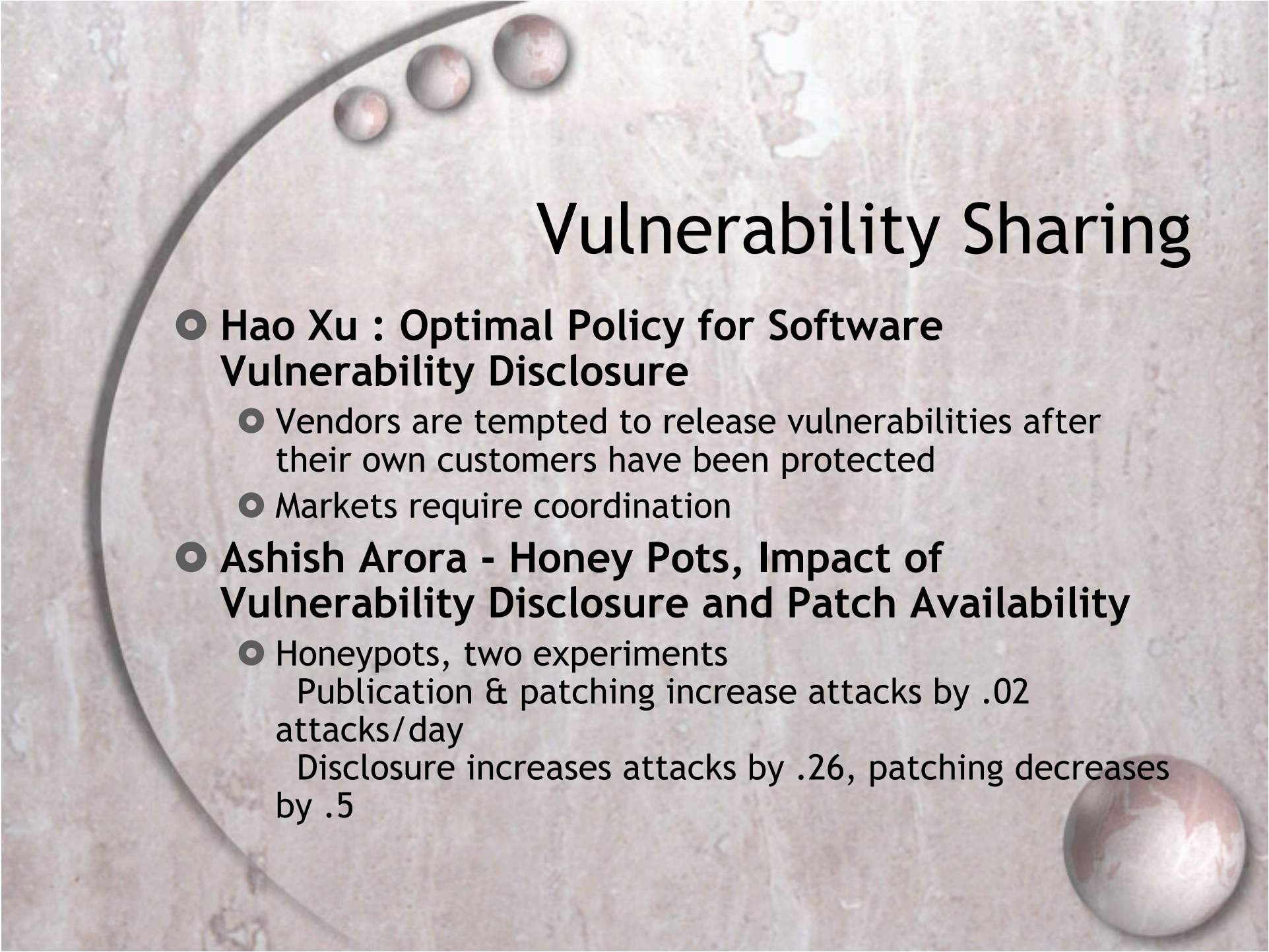
Fundamentals

- Hal Varian, Berkeley, *System reliability and Free Riding*
 - What type of good is computer security
 - Security is a function of most investment, average investment, least investment
- Ross Anderson, *Cryptology and Competition Policy - Issues with Trusted Computing*
 - What are the incentives of private companies?
 - To use security to limit competition
 - Car repair, printer cartridges, cellular batteries
- Jean Camp and C. Wolfram, *Pricing Security*
 - Security vulnerabilities as externalities



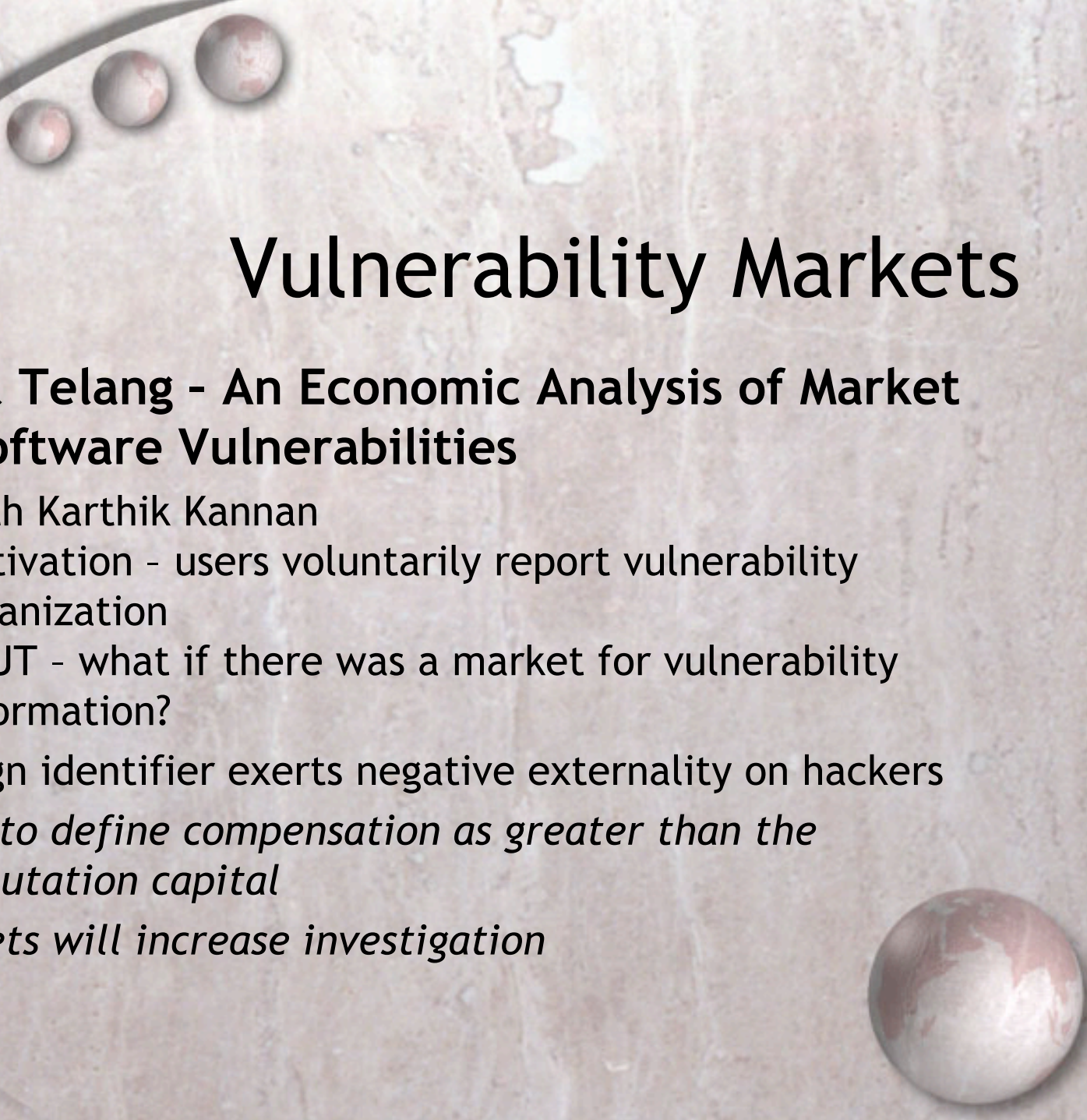
Vulnerability Market

- Stuart Schecter - Towards Econometric Models of Software Security Risks From Remote Attacks
 - Can use markets for vulnerabilities
- Andy Ozment - Bug Auctions: Vulnerability Markets reconsidered
 - No good way to measure software security - market for lemons
 - Producer's motivation for vulnerability markets
 - Improved product quality
 - Useful metrics
 - Vulnerability Auctions - single buyer, many sellers
 - Auctions are a tool to pay for vulnerabilities that coordinate those at risk.



Vulnerability Sharing

- **Hao Xu : Optimal Policy for Software Vulnerability Disclosure**
 - Vendors are tempted to release vulnerabilities after their own customers have been protected
 - Markets require coordination
 - **Ashish Arora - Honey Pots, Impact of Vulnerability Disclosure and Patch Availability**
 - Honeypots, two experiments
 - Publication & patching increase attacks by .02 attacks/day
 - Disclosure increases attacks by .26, patching decreases by .5
- 



Vulnerability Markets

- **Rahul Telang - An Economic Analysis of Market for Software Vulnerabilities**

- With Karthik Kannan

- Motivation - users voluntarily report vulnerability organization

- BUT - what if there was a market for vulnerability information?

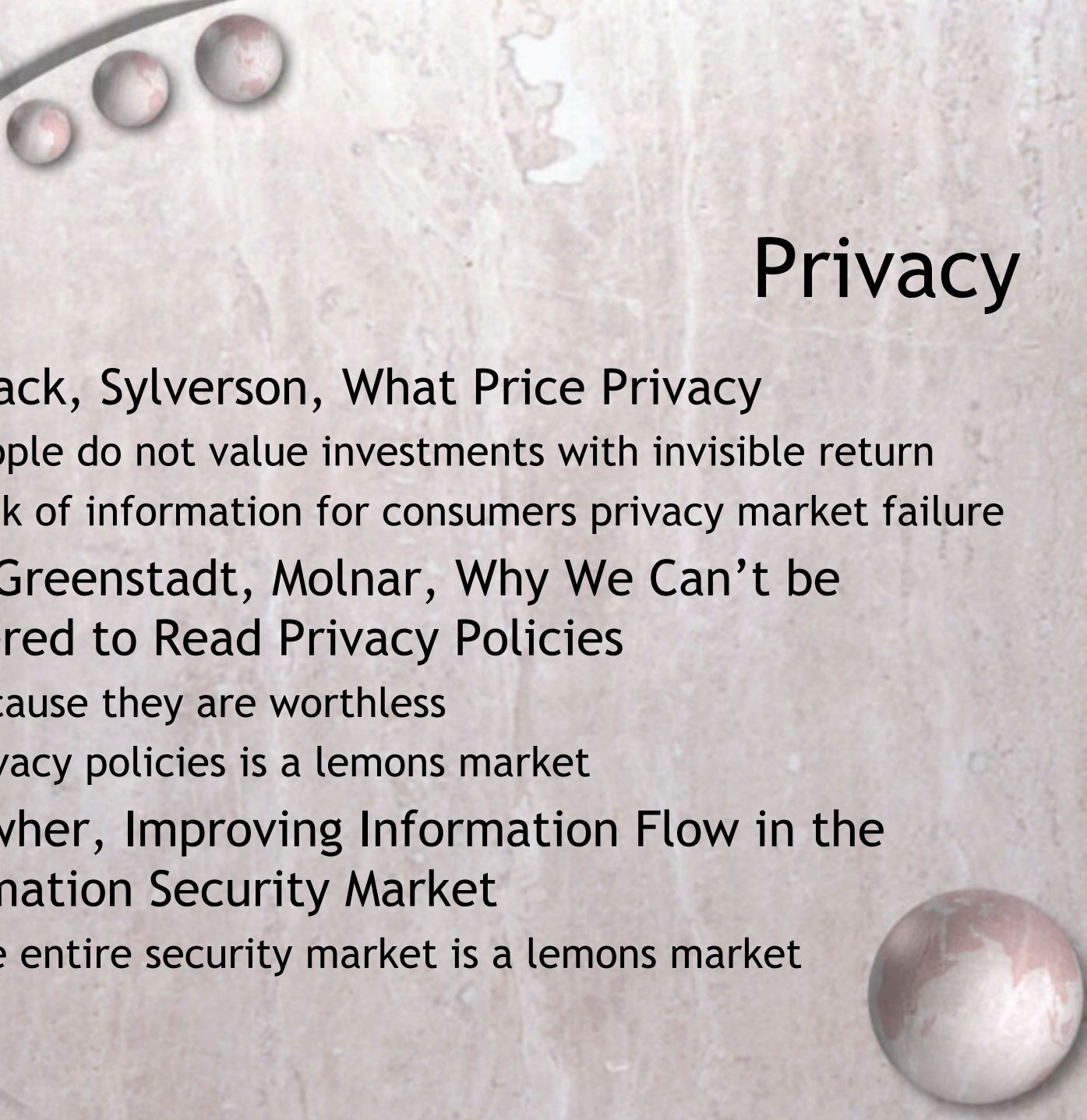
- Benign identifier exerts negative externality on hackers

- Need to define compensation as greater than the reputation capital*

- Markets will increase investigation*

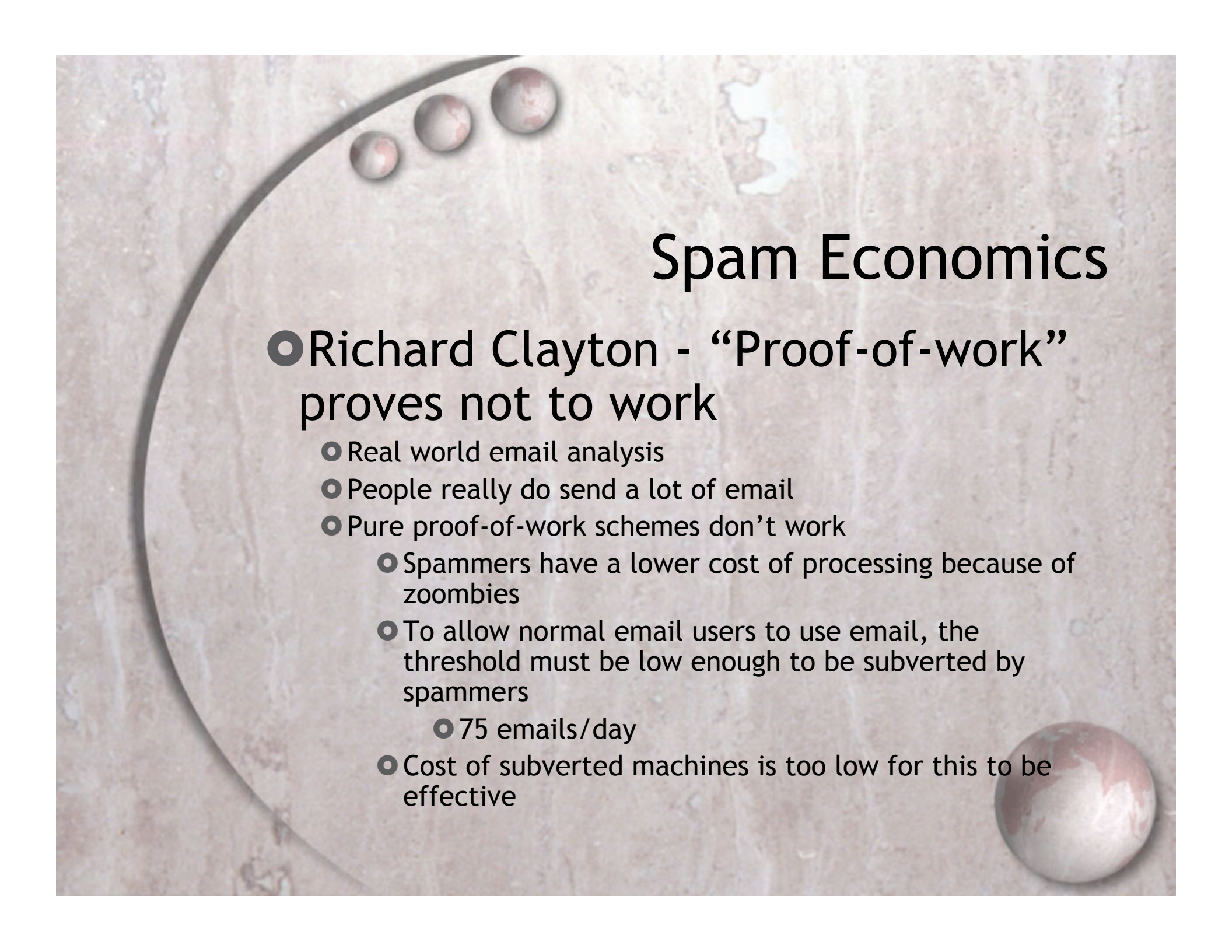
Privacy

- **Hal Varian - Who Signed up for the Do-not-call List?**
 - Us - high education, high network use, credit cards
 - The highest value consumers sign up
 - Is privacy a luxury good?
- **Alessandro Acquisti - Privacy and Rationality**
 - Do individuals care? Can they protect themselves?
Should they?



Privacy

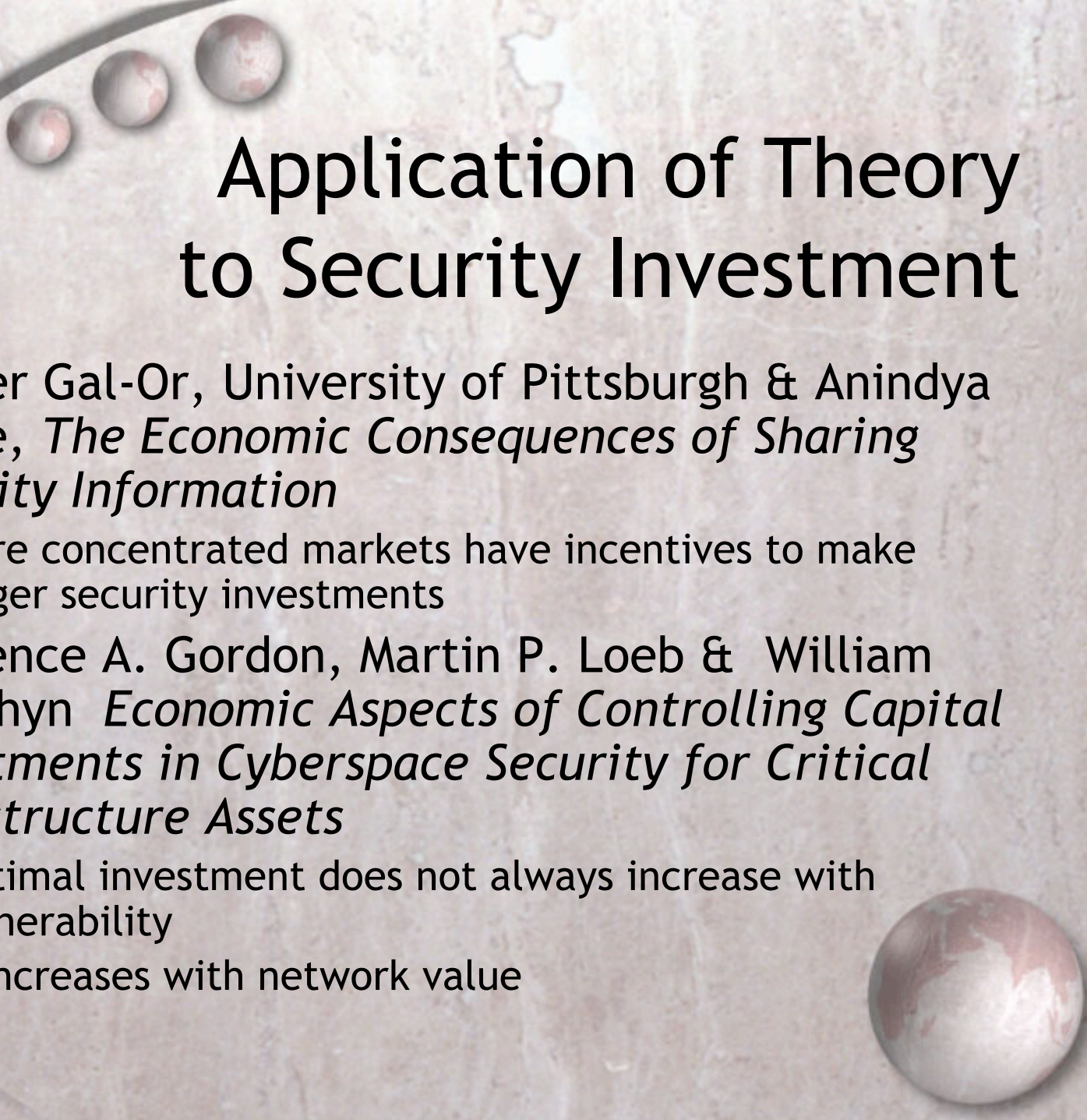
- Shostack, Sylverson, What Price Privacy
 - People do not value investments with invisible return
 - Lack of information for consumers privacy market failure
- Vila, Greenstadt, Molnar, Why We Can't be Bothered to Read Privacy Policies
 - Because they are worthless
 - Privacy policies is a lemons market
- Landwher, Improving Information Flow in the Information Security Market
 - The entire security market is a lemons market



Spam Economics

● Richard Clayton - “Proof-of-work” proves not to work

- Real world email analysis
- People really do send a lot of email
- Pure proof-of-work schemes don't work
 - Spammers have a lower cost of processing because of zombies
 - To allow normal email users to use email, the threshold must be low enough to be subverted by spammers
 - 75 emails/day
 - Cost of subverted machines is too low for this to be effective



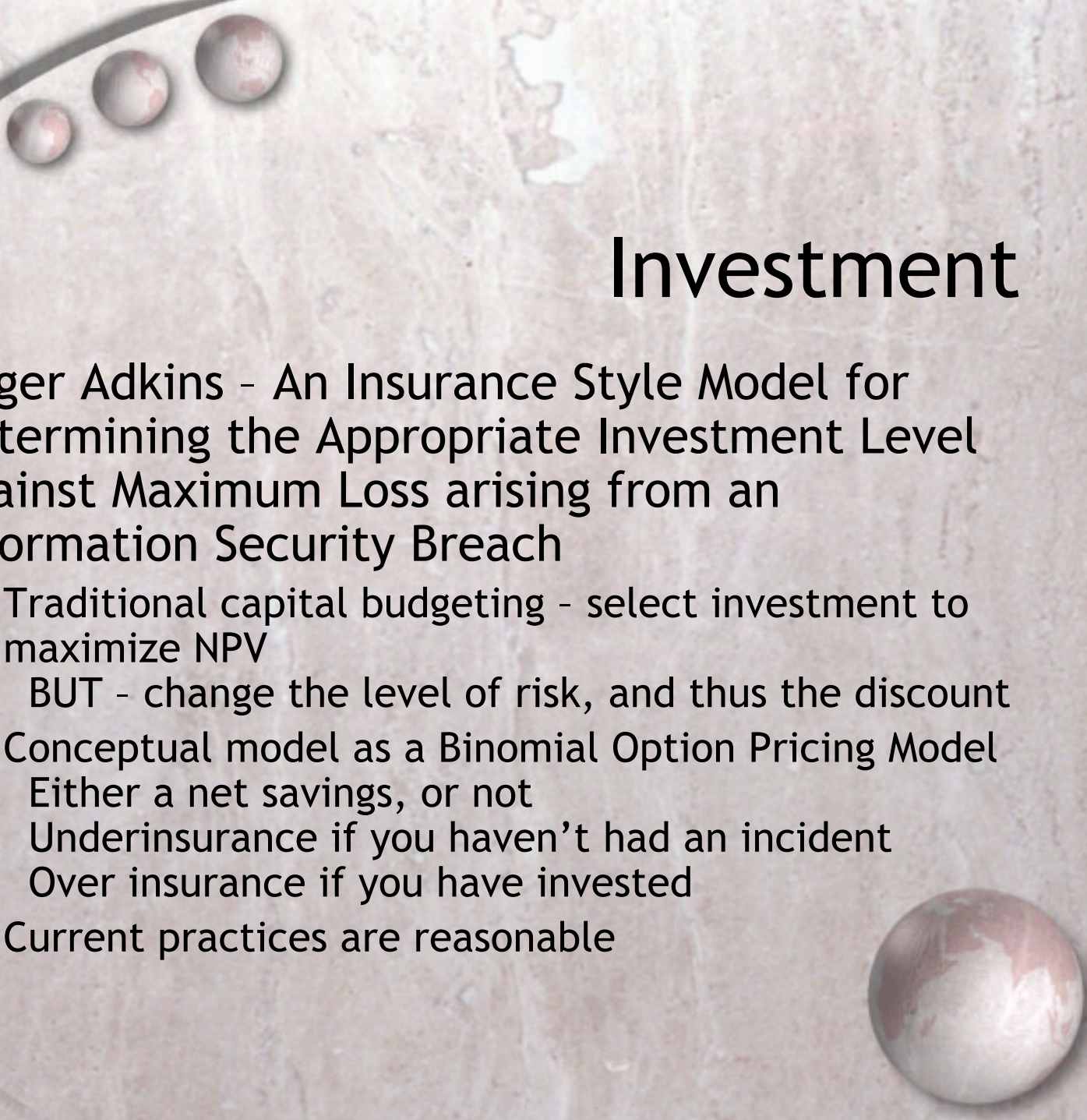
Application of Theory to Security Investment

- Esther Gal-Or, University of Pittsburgh & Anindya Ghose, *The Economic Consequences of Sharing Security Information*
 - More concentrated markets have incentives to make larger security investments
- Lawrence A. Gordon, Martin P. Loeb & William Lucyshyn *Economic Aspects of Controlling Capital Investments in Cyberspace Security for Critical Infrastructure Assets*
 - Optimal investment does not always increase with vulnerability
 - It increases with network value



Consumer Concepts of Privacy

- Acquisit, Grossklags, Privacy Attitudes and Privacy Behavior
 - Individuals see immediate value to information exposure, discount risk
 - Acquisti, Privacy and Security of Personal Information
 - Odlyzko, Privacy, Economics and Price Discrimination
 - Economics of IT-based industry requires price discrimination
 - This requires privacy loss
 - Privacy is for pricing
- 



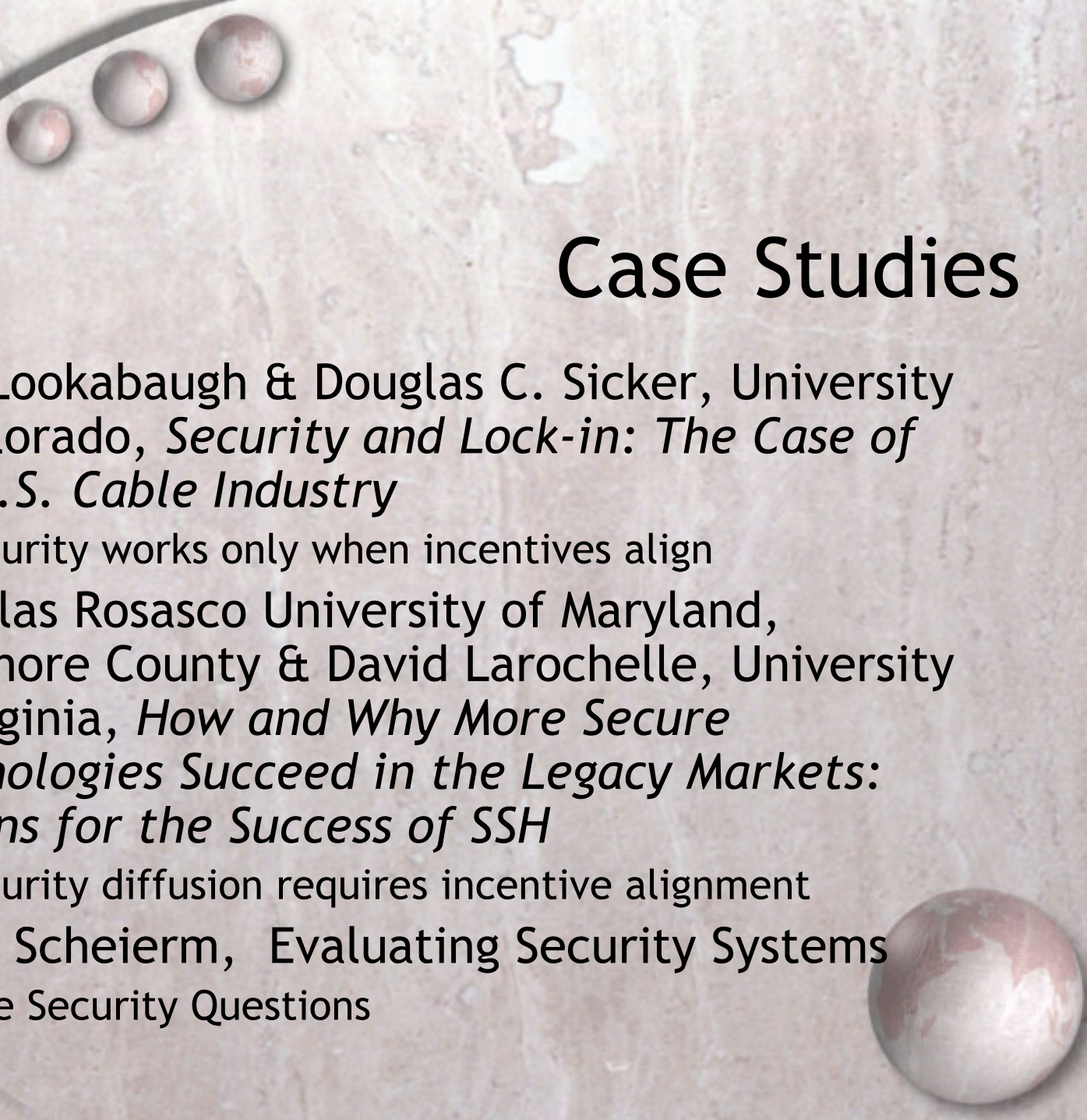
Investment

- Roger Adkins - An Insurance Style Model for Determining the Appropriate Investment Level against Maximum Loss arising from an Information Security Breach
 - Traditional capital budgeting - select investment to maximize NPV
 - BUT - change the level of risk, and thus the discount
 - Conceptual model as a Binomial Option Pricing Model
 - Either a net savings, or not
 - Underinsurance if you haven't had an incident
 - Over insurance if you have invested
 - Current practices are reasonable



Security Technologies Are Not in User Interest

- Mauro Sandrini, *We Want Security But We Hate It: The Foundations of Security Techo-Economics in the Social World*
 - Security is a Technology of Control
 - Until incentives are aligned, users will resist

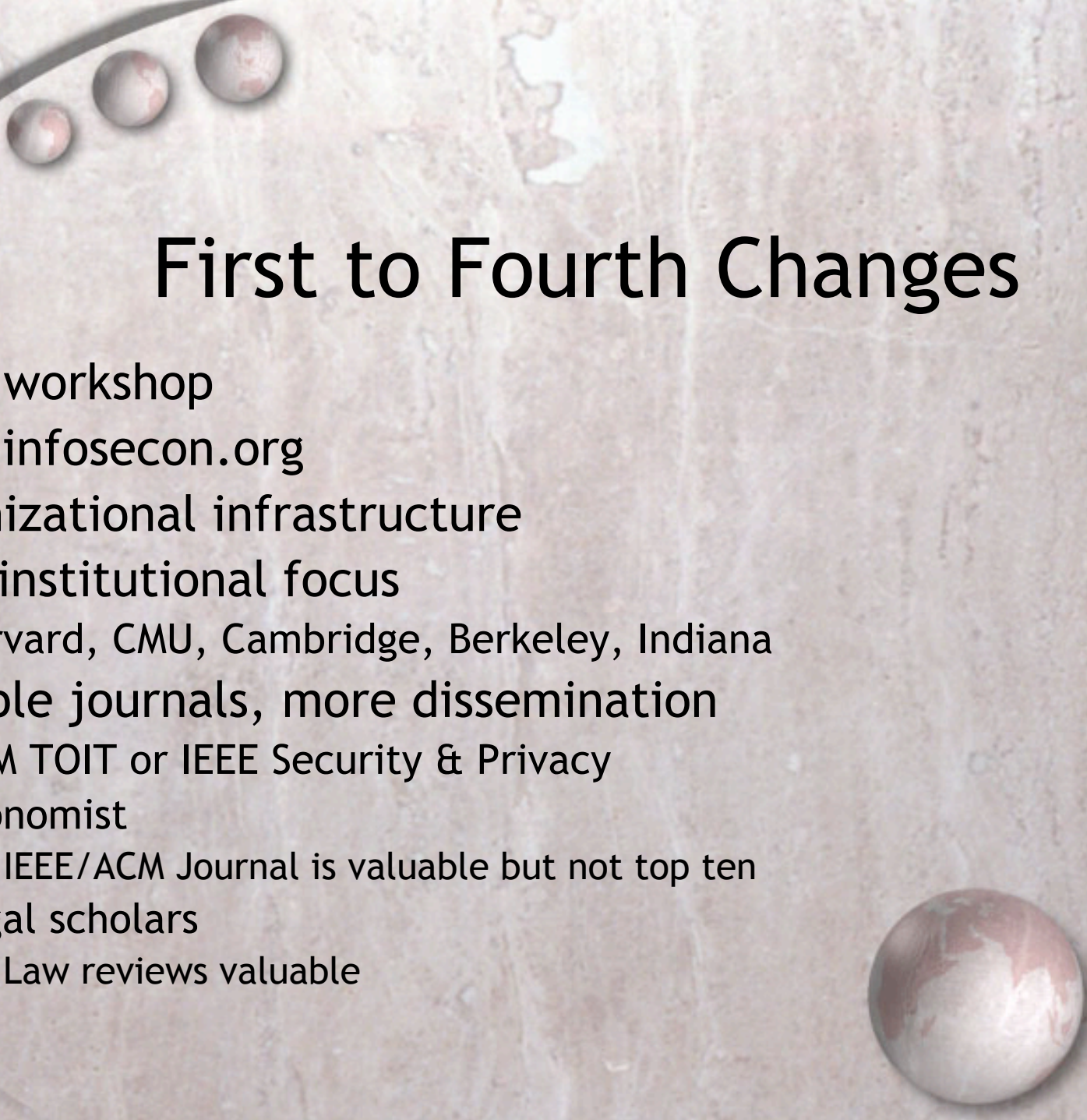


Case Studies

- Tom Lookabaugh & Douglas C. Sicker, University of Colorado, *Security and Lock-in: The Case of the U.S. Cable Industry*
 - Security works only when incentives align
- Nicholas Rosasco University of Maryland, Baltimore County & David Larochelle, University of Virginia, *How and Why More Secure Technologies Succeed in the Legacy Markets: Lessons for the Success of SSH*
 - Security diffusion requires incentive alignment
- Bruce Scheierm, *Evaluating Security Systems*
 - Five Security Questions

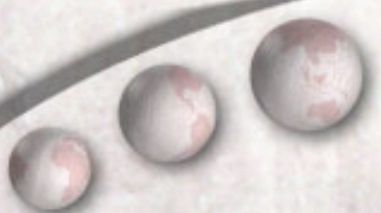
Workshops are Critical Component in Investigation

- Multiple publication paths after the workshop
- Workshops enable cross-barrier
 - Without requiring commitment to publish
 - Full proceedings on-line for
 - All workshops
 - Economics of Information Security edited text



First to Fourth Changes

- Open workshop
- www.infoecon.org
- Organizational infrastructure
- More institutional focus
 - Harvard, CMU, Cambridge, Berkeley, Indiana
- Multiple journals, more dissemination
 - ACM TOIT or IEEE Security & Privacy
 - Economist
 - IEEE/ACM Journal is valuable but not top ten
 - Legal scholars
 - Law reviews valuable



Future
May 2005 Harvard Economics
Workshop

1-3 June 2005

www.infoecon.net/workshop

Papers on spam,
vulnerabilities, DRM &
security, economics of privacy

